Approach Paper – Escalation & Resolution of 'Not Accepted' Internal Audit Findings

1. Purpose and Context

At its meeting on **11 December 2025**, the Board Audit Committee (BAC) reviewed the status of open audit actions and noted instances where audit findings were marked **"Not Accepted"** and remained unresolved beyond issuance of the final audit report.

The Committee directed that Group Internal Audit (GIA), in consultation with the Group Chief Executive Officer, formalise the escalation and resolution process for such cases (BAC Action #2, Meeting 5 FY2025).

This paper responds to that directive by proposing a clear, governance-aligned framework to ensure that High & Very High-risk audit findings, not accepted by Management are escalated through established management risk forums for resolution, with clear accountability and appropriate Board Audit Committee visibility.

2. Existing Policy Framework

The current **GIA Manual (effective 30 September 2025)** establishes escalation requirements for audit findings not accepted by Management:

- **Section 11.4.6** requires that where agreement cannot be reached with management, the matter is escalated to the **Group Chief Audit Officer (GCAO)** and reflected in the final audit report with an appropriate **GIA comment**.
- **Section 11.4.7** requires further escalation where:
  - Management does not accept an audit finding, or
  - Management accepts risk beyond approved appetite, with communication to the **Board Audit Committee or a relevant management forum**, as appropriate.

These provisions ensure escalation and transparency. However, they do not explicitly define **how final management decisions are reached** once an audit report has been issued and a fundamental disagreement remains unresolved.

A fundamental disagreement is deemed to exist where management:

- Disputes the factual accuracy of the finding and/or the factual basis for the required action plan;
- Disputes the existence or severity of a control weakness;
- Proposes remediation that is materially inadequate to address the risk; or
- Seeks to accept risk beyond the approved risk appetite/limit

3. Governance Rationale

The proposed approach is intended to clarify **decision ownership and resolution mechanics** once audit reporting is complete and a fundamental disagreement remains. GIA's role is to provide independent assessment, challenge management positions where appropriate, and escalate matters where resolution is not achieved. Decisions on remediation strategies or risk acceptance appropriately sit with management and should be taken through established **enterprise risk governance forums**, rather than remaining within audit follow-up mechanisms.

Audit findings will, in the first instance, be grounded in deviations from the Bank's approved policies, processes/standards, and applicable laws or regulations. Where gaps in governance or control standards exist (i.e., matters not explicitly covered by existing policies/procedures), GIA may reference expected control principles and leading practices, with appropriate calibration and evidence to minimise subjective judgement.

*This approach does not alter audit conclusions, ratings, or management ownership of actions. It ensures that unresolved audit matters are addressed through a **consistent, decision-oriented governance pathway**.*

4. Scope and Applicability

The escalation framework applies **only to High & Very High-risk audit findings**, reflecting materiality, proportionality, and the Board Audit Committee's intent.

Medium and Low-risk findings will continue to be managed through standard audit follow-up and monitoring processes, and are outside the scope of this approach.

5. Escalation and Resolution Framework

Tiered Escalation Pathway for Not-Accepted Audit Findings

Stage	Trigger	Forum and Process	Outcome
Stage 1 – Engagement-Level Resolution	Management responds *"Not Accepted"* to a High, Very High risk finding	Audit Manager and Action Owner seek resolution during draft report discussions	Agreement reached or deadlock identified
Stage 2 – GCAO Engagement	Deadlock persists following Stage 1	GCAO engages the relevant Business / Function Head; findings are issued in the final audit report with GIA commentary and an indicative remediation timeline aligned to the next scheduled relevant MRC/MCRC meeting, to ensure timely escalation and decision-making.*	Resolution achieved or confirmation of a fundamental disagreement
Stage 3 – Executive Management Resolution	Fundamental disagreement persists on a High/Very High-risk audit finding	GIA formally escalates its position to Executive Management for management consideration and resolution. The GCEO consults the relevant GMC members to determine the appropriate management outcome.	Resolution achieved or confirmation that the disagreement remains unresolved and requires escalation to formal management governance forums.
Stage 4 – Management Committee (MRC/MCRC)	Fundamental disagreement remains unresolved post-Executive Management Resolution	GIA submits a concise **Audit Risk Resolution Brief** to the Management Risk Committee (MRC) for consideration and decision; where the disputed matter relates primarily to regulatory or compliance obligations, the matter may be routed to the Management Compliance Risk Committee (MCRC).	MRC/MCRC determines the mandated remediation, including approved timelines and/ or formal risk acceptance (where permissible), including duration and conditions^

**Final management remediation timelines or formal risk acceptance decisions will be determined by the MRC/MCRC, with BAC visibility/oversight as set out in Section 7.*

^The MRC/MCRC acts as decision forum and does not re-litigate audit findings or reopen audit conclusions.

6. Audit Risk Resolution Brief

Where escalation to the Management Risk Committee/Management Compliance Risk Committee is required (Stage 4), GIA will submit a concise **Audit Risk Resolution Brief** (Appendix A), structured as a **decision paper**.

The Brief is intended to:

- Clearly articulate the risk and the nature of the disagreement

- Summarize the respective positions of GIA and management and the steps already taken to overcome the aspects of disagreements

Relevant extracts from the issued audit report may be included **as reference only**, where necessary. The Brief itself will remain focused on enabling an informed and timely decision, rather than re-opening audit debate.

7. Oversight and Reporting

- The **Management Risk Committee/Management Compliance Risk Committee** serves as the final management decision authority for High & Very High-risk audit findings not accepted by Management, in respect of remediation or formal risk acceptance.
- Outcomes of Executive Management/MRC/MCRC deliberations will be documented and reflected in audit action tracking and follow-up processes in Teammate (Audit Management System).
- The **Board Audit Committee** (BAC) will be provided with visibility over audit matters escalated through this framework, including both resolved and unresolved cases, their resolution status and the outcomes of **Executive Management/Management Risk Committee/Management Compliance Risk Committee** deliberations, to enable effective oversight. Where the BAC meeting precedes the relevant Management forum discussion, updates on resolutions (including remediation versus formal risk acceptance) will be provided in the subsequent BAC reporting cycle.
- In exceptional circumstances involving significant governance, regulatory, or risk-appetite concerns, Group Internal Audit may highlight such matters to the Board Audit Committee as part of its independent reporting.

Appendix A - Audit Risk Resolution Brief (Template)
(One-Page Decision Paper for Management Risk Committee/Management Compliance Risk Committee)

Audit Risk Resolution Brief
Audit: [Audit name and reference]
Audit Report Date: [Report Date]
Finding Reference: [Finding number / title]
Risk Rating: High / Very High
Prepared by: Group Internal Audit
Date: [Insert date]

---

1. **Context**

Brief description of the audit area and the finding, including why the matter has been escalated to the Management Risk Committee/Management Compliance Risk Committee (i.e. persistent disagreement following audit issuance and completion of the applicable escalation stages).

2. **Risk Statement**
Concise statement of the risk, addressing:

- What could go wrong
- Why it matters
- Potential impact if the issue remains unresolved

3. **GIA Position**
Summary of GIA's assessment, including:

- Nature of the control weakness
- Basis for the risk rating
- Key concerns arising from non-acceptance

4. **Management Position**
Summary of management's rationale for non-acceptance, including:

- Reasons for disagreement
- Mitigating factors cited
- Any alternative controls relied upon

5. **Constraints and Considerations**
Key considerations relevant to the decision, such as:

- Regulatory or compliance constraints
- Risk appetite implications
- Dependencies or timing considerations

6. **Decision Required from the Management Risk Committee/Management Compliance Risk Committee**
The Committee is requested to determine one of the following:

☐ Mandate remediation by [date]
☐ Approve formal risk acceptance until [date], subject to conditions (where permissible), including whether the activity/new business may continue until closure or should be paused, as determined by management.

7. **Reference**
- Relevant extract(s) from the issued audit report
- GIA commentary, where necessary